



INFORME EJECUTIVO DE AUTOEVALUACIÓN

Cumplimiento LOPDP · Madurez Institucional · Gobernanza Tecnológica

INSTITUCIÓN C

Tipo de Institución	Fiscomisional
Responsable de la autoevaluación	XXXXXXX
Cargo	Director General
Fecha de aplicación	2026-07-31
Revisado por	María Armijos

INDICADORES CLAVE

CUMPLIMIENTO LOPDP

31.0%

MADUREZ INSTITUCIONAL

1.9 / 5

GOBERNANZA TI

26.8%

ÍNDICE DE CUMPLIMIENTO GLOBAL

31.8%

Riesgo Alto — Acción inmediata

1. Resumen por módulo

Módulo	% Cumplimiento / Madurez	Sí	Parcial	No
Módulo 1 · Cumplimiento LOPDP/RGLOPDP	31.0%	2	14	13
Módulo 2 · Madurez Institucional	1.9 / 5 (37.6%)	—	—	—
Módulo 3 · Gobernanza Tecnológica	26.8%	1	13	14

2. Hallazgos principales — criterios no cumplidos

Módulo	ID	Criterio
Módulo 1	B3	¿Existe una política de privacidad clara, accesible y revisada periódicamente?
Módulo 1	B4	¿Se proporciona a los titulares información sobre cómo ejercer sus derechos (ARCO+)?
Módulo 1	B5	¿Cuenta con política de uso de cookies con consentimiento informado?
Módulo 1	D1	¿La institución tiene designado formalmente un Delegado de Protección de Datos (DPD)?
Módulo 1	D2	¿Cuenta con contratos firmados con encargados de tratamiento externos?
Módulo 1	E3	¿Se realiza Evaluación de Impacto en Protección de Datos (EIPD) para tratamientos de alto riesgo?
Módulo 1	E4	¿Mantiene un procedimiento documentado para notificación de vulneraciones de seguridad?
Módulo 1	E5	¿Realiza análisis de vulnerabilidades informáticas relacionadas con datos personales?
Módulo 1	E6	¿Cuenta con políticas de anonimización, cifrado y eliminación segura de datos?
Módulo 1	F1	¿Se realizan capacitaciones periódicas a docentes, autoridades, estudiantes sobre protección de datos?
Módulo 1	F2	¿Se realizan revisiones periódicas y auditorías de cumplimiento de protección de datos?
Módulo 1	F3	¿Se ha documentado y aplica una política de retención y eliminación de datos?
Módulo 1	F4	¿Se realizan pruebas de penetración o análisis de seguridad informática?
Módulo 3	TG1	¿Existe un plan estratégico de tecnología de la información (PETI) vigente y alineado al plan institucional?
Módulo 3	TG3	¿Existe un comité o instancia de toma de decisiones tecnológicas en la institución?
Módulo 3	TA1	¿Se cuenta con un inventario actualizado de hardware (equipos, servidores, dispositivos de red)?
Módulo 3	TA2	¿Se cuenta con un inventario actualizado de software y licencias?
Módulo 3	TA3	¿Están identificados y clasificados los sistemas de información por criticidad?
Módulo 3	SI1	¿Los sistemas de información institucionales están documentados (arquitectura, flujos de datos, usuarios)?
Módulo 3	SI3	¿Los sistemas aplican controles de acceso basados en roles (RBAC) o perfiles de usuario?
Módulo 3	SI5	¿Los sistemas de información críticos cuentan con planes de continuidad o contingencia?
Módulo 3	SEC3	¿Se usan herramientas de protección perimetral (firewall, antivirus, IDS/IPS)?
Módulo 3	SEC6	¿Se realizan pruebas de seguridad (pentesting, ethical hacking) periódicamente?
Módulo 3	SV1	¿Existe un sistema de gestión de incidentes y solicitudes TI (mesa de ayuda / help desk)?
Módulo 3	SV3	¿Existen Acuerdos de Nivel de Servicio (SLA) con proveedores tecnológicos críticos?
Módulo 3	SV4	¿Existe gestión de cambios formalizada para modificaciones en sistemas productivos?

Módulo	ID	Criterio
Módulo 3	CN2	¿Se aplica el Esquema Gubernamental de Seguridad de la Información (EGSI) o similar?

Dimensiones de madurez con nivel bajo (nivel 1-2)

ID	Dimensión	Nivel
G1	Existe una estructura de gobierno de datos con roles y responsabilidades definidos (Responsable, DPD, Encargados).	1
G2	La alta dirección lidera y está comprometida con el cumplimiento normativo en protección de datos.	2
G3	Existen políticas institucionales formalizadas sobre privacidad y protección de datos personales.	2
G4	Se cuenta con presupuesto asignado para actividades de cumplimiento y protección de datos.	1
P1	Los procesos de tratamiento de datos están documentados, aprobados y comunicados al personal.	2
P2	Existe un registro de actividades de tratamiento (RAT) actualizado.	1
P3	Se aplican procedimientos formales para responder derechos ARCO+ de los titulares.	1
P4	Se dispone de procedimientos para gestión de incidentes y brechas de datos.	1
P5	Existe un proceso de revisión y mejora continua de los procedimientos de protección de datos.	1
CC1	El personal tiene conocimiento básico de la LOPDP y sus obligaciones.	2
CC2	Se realizan capacitaciones formales y periódicas sobre protección de datos a todos los niveles.	2
R1	Se realiza análisis de riesgos formal para el tratamiento de datos personales.	1
R2	Los riesgos identificados tienen controles asignados, responsables y plazos de mitigación.	2
R3	Se aplican Evaluaciones de Impacto en Protección de Datos (EIPD) cuando corresponde.	1
R4	Las medidas de seguridad técnica (cifrado, control de acceso, logs) están implementadas y documentadas.	2
R5	Se realizan pruebas periódicas de seguridad (pentesting, análisis de vulnerabilidades).	2
T3	Existe un registro actualizado de encargados de tratamiento externos.	2
A1	Se realizan auditorías internas periódicas de cumplimiento en protección de datos.	1
A2	Existen indicadores y métricas de cumplimiento que se monitorean regularmente.	2
A3	Los hallazgos de auditoría se documentan, priorizan e implementan con seguimiento.	1
A4	La institución aplica un ciclo de mejora continua (PHVA) en la gestión de datos personales.	1

3. Hoja de ruta por módulo

Cada módulo se interpreta de forma independiente según el rango de cumplimiento alcanzado. El resultado indica qué debe lograr la institución en esa etapa y las acciones concretas para avanzar al siguiente rango.

MÓDULO 1 · Cumplimiento LOPDP/RGLOPDP

31.0% · Rango 30%–60% · Cumplimiento en desarrollo / formalización

Qué debe lograr	Demostrar que los requisitos ya documentados se ejecutan.
Acciones prioritarias	1) Validar RAT por área. 2) Implementar registros de consentimiento cuando aplique. 3) Operar atención de derechos. 4) Ejecutar análisis de riesgos. 5) Realizar EIPD cuando corresponda. 6) Implementar controles de seguridad prioritarios. 7) Gestionar incidentes y simulacros. 8) Evaluar encargados. 9) Ejecutar conservación/eliminación. 10) Capacitar al personal.
Entregables principales	RAT validado; registro de consentimientos/revocatorias; expedientes de derechos; matriz de riesgos; EIPD aplicables; evidencias técnicas; registro/simulacro de incidentes; evaluaciones de proveedores; actas de eliminación; registros de capacitación.
Indicadores de salida	>= 90% tratamientos con información/RAT completa; >= 90% controles prioritarios operativos; >= 90% terceros críticos evaluados; derechos atendidos en plazo.
Prioridad	ALTA
Responsables sugeridos	DPD + áreas + TI + Jurídico + Compras
Criterio para avanzar de rango	Los controles funcionan y existe evidencia de ejecución, no solo documentos.

MÓDULO 2 · Madurez Institucional

37.6% · Rango 30%–60% · Madurez en desarrollo / repetible

Qué debe lograr	Hacer que los procesos se ejecuten de forma consistente.
Acciones prioritarias	1) Ejecutar procedimientos. 2) Capacitar por rol. 3) Asignar presupuesto. 4) Operar riesgos con responsables/plazos. 5) Gestionar terceros. 6) Medir derechos/incidentes/capacitación. 7) Ejecutar auditorías básicas. 8) Dar seguimiento a hallazgos.
Entregables principales	Plan anual de privacidad; presupuesto; registros de ejecución; KPI; matriz de riesgos con tratamiento; evaluaciones de terceros; informes de auditoría; acciones correctivas.
Indicadores de salida	>= 90% procesos críticos con evidencia; >= 90% personal objetivo capacitado; riesgos altos con responsable y fecha.
Prioridad	ALTA
Responsables sugeridos	Dirección + DPD + RRHH + áreas
Criterio para avanzar de rango	Los procesos son repetibles y no dependen exclusivamente de personas.

MÓDULO 3 · Gobernanza Tecnológica

26.8% · Rango 0%–30% · Gobernanza TI inicial / brechas críticas

Qué debe lograr	Establecer control mínimo sobre tecnología que trata datos personales.
Acciones prioritarias	1) Definir responsable/unidad TI. 2) Inventariar hardware/software. 3) Clasificar sistemas críticos. 4) Documentar sistemas y flujos. 5) Aprobar política de seguridad. 6) Establecer controles de acceso. 7) Crear respaldos. 8) Crear mesa de ayuda. 9) Identificar requisitos normativos. 10) Iniciar Privacy by Design.
Entregables principales	PETI/plan TI inicial; organigrama TI; inventario de activos; catálogo de sistemas; diagramas de flujos; política de seguridad; matriz de accesos; procedimiento de respaldos; help desk; matriz de requisitos legales.
Indicadores de salida	100% sistemas críticos identificados; activos críticos con propietario; controles críticos definidos.
Prioridad	CRÍTICA
Responsables sugeridos	Dirección + TI + DPD
Criterio para avanzar de rango	No existen sistemas críticos desconocidos ni controles básicos ausentes.

Este informe fue generado automáticamente a partir de las respuestas registradas en el Instrumento de Autoevaluación Institucional. La hoja de ruta por módulo proviene del Modelo de Madurez LOPDP institucional. Para el detalle completo de los 82 criterios evaluados, consulte el archivo Excel adjunto.

4. Formato de consentimiento digital

1.1.1. FORMATO DE CONSENTIMIENTO DIGITAL

1. ACEPTACIÓN

Declaro que he leído y comprendido la información contenida en el presente consentimiento informado y que he sido informado/a de manera clara, suficiente y comprensible sobre el tratamiento de mis datos personales.

- ☐ ACEPTO el tratamiento de mis datos personales para las finalidades descritas en el presente consentimiento informado.
- ☐ ACEPTO el uso de imagen, fotografía y/o material audiovisual, cuando aplique.
- ☐ ACEPTO el tratamiento de datos sensibles, cuando aplique.

La aceptación otorgada será registrada electrónicamente por la plataforma utilizada, conservando la evidencia necesaria para acreditar la identidad o autenticación del usuario, así como la fecha, hora y demás registros asociados a la manifestación de voluntad realizada.

EVIDENCIA DE REGISTRO ELECTRÓNICO

Usuario: XXXXXXXXXXXX · Cargo: Director General

Fecha: 14/8/2026 · Hora: 9:32:48 a. m.

Estado del consentimiento: Completo